



Escuela de Ingeniería y Ciencias
Ingeniería en Ciencias de Datos y Matemáticas

Etapas 1 del reto: Gestor de Identidades

Reporte Técnico

Estudiantes y matrículas

Alberto Palomino Carvajal – A01571511
Carlos Cuéllar Solís – A01571619
Daniel Rodríguez Gallegos – A01285849
Leonardo Albarran Valdes – A01571750
Luis Javier Jacobo Morimoto – A01571679
Viviana Carrizales Luna – A01286191

Equipo: 2 Grupo: MA2006B.602

Profesores:

Raúl Gómez Muñoz Daniel Otero Fadul Alberto F. Martínez

Socio Formador: Casa Monarca – Ayuda Humanitaria al Migrante, A.C.

Monterrey, Nuevo León – 15 de mayo de 2026

Índice de Contenidos

0.1. Índice de Contenidos	1
0.2. Índice de Figuras	1
0.3. Abstract	1
0.4. Introducción	1
0.5. Marco de Referencia	2
0.6. Desarrollo	2
0.6.1. Propuesta	2
0.6.2. Desarrollo de componentes	3
0.6.3. Conexión de los componentes	3
0.7. Resultados	9
0.7.1. Lo que se obtiene para BackEnd	9
0.7.2. Lo que se obtiene para FrontEnd	9
0.7.3. Lo que se obtiene en la solución completa	9
0.7.4. Casos de uso y tabla de validaciones	10
0.8. Conclusiones y trabajo futuro	18
0.9. Referencias	18
0.10. Inteligencia artificial	18

Índice de Figuras

1. Arquitectura general del sistema de gestión de identidades.	4
2. Diagrama de secuencia: proceso de autenticación y emisión de token JWT.	5
3. Diagrama de secuencia: proceso de Alta de una identidad digital.	6
4. Diagrama de secuencia: proceso de revocación de un certificado digital.	7
5. Diagrama de secuencia: proceso de baja definitiva (eliminación física) de una identidad.	8
6. tabla de pruebas	17

Abstract

Este proyecto nació de una necesidad real: Casa Monarca, una organización que acompaña diariamente a personas migrantes y refugiadas en Monterrey, no contaba con ningún mecanismo formal para controlar quién accede a su información ni para revocar ese acceso cuando alguien deja de colaborar. Los datos que manejan son sensibles, y la ausencia de trazabilidad representaba un riesgo legal y operativo concreto.

Para resolver esto, se construyó un gestor de identidades digitales que cubre el ciclo de vida completo de cada colaborador dentro del sistema: desde su registro hasta su baja definitiva, pasando por revocaciones, revalidaciones y extensiones de certificados. Cada identidad lleva asociado un certificado digital X.509 respaldado por criptografía RSA de 2048 bits, y ninguna llave privada ni contraseña se almacena jamás en texto plano. La autenticación opera mediante tokens JWT, la autorización sigue una jerarquía de cuatro roles y cada acción queda registrada en un log de auditoría inmutable.

El resultado es un sistema funcional, autocontenido y construido íntegramente con tecnologías abiertas, que le brinda a Casa Monarca algo que antes no tenía: control real y demostrable sobre las llaves de su casa.

Introducción

De acuerdo con Casa Monarca (s.f.), Casa Monarca es una organización que trabaja diariamente con personas en situación de migración y refugio. Como cualquier organización que opera con datos personales en México, tiene obligaciones legales claras respecto a cómo los protege y quién tiene acceso a ellos. El problema es que, hasta ahora, no contaba con ningún mecanismo formal para controlar esto digitalmente. Los accesos se gestionaban de manera informal, sin registros, sin trazabilidad y sin una forma confiable de revocarlos cuando alguien dejaba de colaborar con la organización.

Este proyecto resuelve precisamente eso. Se construyó un sistema que gestiona el ciclo de vida completo de las identidades digitales de los colaboradores de Casa Monarca: desde el momento en que una persona

se incorpora hasta que se retira, pasando por cualquier cambio de rol o situación intermedia. Cada identidad lleva asociado un certificado digital real, emitido bajo estándares criptográficos vigentes, que acredita quién es esa persona dentro del sistema y qué nivel de acceso posee.

El resultado es una herramienta que brinda a la organización control, visibilidad y trazabilidad sobre algo tan fundamental como saber, en cualquier momento, quién tiene las llaves de su casa.

Marco de Referencia

Para construir el marco de referencia, se revisaron soluciones existentes relacionadas con infraestructura de clave pública, certificados digitales, bibliotecas criptográficas en Python y sistemas institucionales de identidad digital. En particular, se analizaron modelos PKI, el estándar X.509, el algoritmo RSA, bibliotecas como PyCryptodome y cryptography, además de escenarios reales como la e.firma del SAT. De estas referencias se tomaron ideas concretas para la solución, como vincular una identidad con una llave pública, emitir certificados con vigencia, proteger llaves privadas y organizar el ciclo de vida de identidades mediante altas, bajas, revocaciones y rastreo.

Desde el punto de vista técnico, se revisó el modelo de infraestructura de clave pública, conocido como PKI, en el que una autoridad certificadora emite certificados digitales que permiten asociar una identidad con una clave pública. Este modelo se relaciona con el estándar X.509 y con la RFC 5280, donde se describe el uso de certificados digitales dentro de infraestructuras de clave pública. De esta referencia se tomó la idea de emitir certificados para ciertas identidades del sistema, administrar su periodo de validez y asociarlos con una autoridad certificadora interna. También se revisó el sistema de e.firma del SAT como ejemplo de administración institucional de identidades, ya que muestra cómo una persona puede vincularse formalmente con certificados, llaves y vigencias dentro de un sistema de confianza.

En relación con los contenidos del bloque, se revisó RSA como algoritmo de clave pública basado en conceptos de aritmética modular, exponentes, congruencias y factorización de enteros grandes. Esta revisión permitió conectar la teoría matemática con una aplicación real de seguridad. Además, se consideró PyCryptodome como biblioteca de Python para trabajar con criptografía de clave pública, ya que permite generar, importar y exportar llaves RSA. Sin embargo, para la implementación final se utilizó principalmente la biblioteca cryptography, porque integra herramientas para generar llaves RSA, construir certificados X.509, firmarlos, serializarlos en formato PEM y proteger claves privadas mediante Fernet.

Finalmente, se revisaron buenas prácticas de seguridad para autenticación, autorización y auditoría. De estas referencias se tomó la decisión de no almacenar contraseñas en texto plano, por lo que el sistema utiliza hashes bcrypt mediante passlib. También se incorporó JWT para manejar sesiones con expiración y un modelo de permisos basado en roles jerárquicos, siguiendo el principio de mínimo privilegio. Además, se integró una tabla de auditoría para registrar acciones relevantes, como altas, revocaciones, bajas, descargas de certificados, certificados efímeros e inicios de sesión. Con esto, las soluciones revisadas no solo funcionan como antecedentes teóricos, sino que justifican decisiones concretas dentro del prototipo desarrollado con FastAPI, SQLAlchemy, SQLite y un frontend HTML.

Desarrollo

Propuesta

El sistema desarrollado es un gestor centralizado del ciclo de vida de identidades digitales, diseñado para organizaciones que requieren control estricto sobre quién accede a sus recursos y bajo qué condiciones. La propuesta se basa en cuatro operaciones fundamentales —Alta, Revocación, Baja y Rastreo— respaldadas por criptografía estándar de industria. Cada identidad dentro del sistema está asociada a un certificado digital X.509 y a un par de llaves RSA de 2048 bits, generados automáticamente al momento del registro. La autenticación se realiza mediante tokens JWT de duración limitada, y la autorización se rige por una jerarquía de cuatro roles: Admin, Coordinator, Operative y External. Un principio central de la propuesta es que ningún material criptográfico sensible se almacena en texto plano: las contraseñas se protegen con hashing bcrypt y las llaves privadas se cifran con AES antes de persistirse en base de datos.

Desarrollo de componentes

El sistema se construyó con Python y el framework FastAPI, y se organizó en módulos independientes con responsabilidades bien delimitadas.

Núcleo criptográfico (`app/core/crypto.py`). Este módulo concentra toda la lógica de seguridad. Implementa la generación de pares de llaves RSA, la construcción de una Autoridad Certificadora raíz autofirmada y la emisión de certificados X.509 para usuarios. También maneja el cifrado simétrico de llaves privadas mediante la primitiva Fernet (que internamente aplica AES-128-CBC con HMAC-SHA256), derivando la clave de cifrado a partir de la `SECRET_KEY` del sistema mediante SHA-256. Adicionalmente, gestiona la creación y verificación de tokens JWT firmados con el algoritmo HS256, y expone una dependencia de FastAPI (`get_current_identity`) que valida la sesión activa en cada petición protegida.

Capa de datos (`app/models/` y `app/db/`). Se definieron dos modelos ORM mediante SQLAlchemy: `Identity`, que almacena los datos del colaborador junto con su certificado, llave pública y llave privada cifrada; y `AuditLog`, que registra de forma inmutable cada evento relevante del sistema, incluyendo el identificador del actor que lo ejecutó, la acción realizada y una descripción del contexto. La base de datos utilizada es SQLite, con un mecanismo de migración incremental que añade columnas nuevas en arranque sin destruir datos existentes.

Lógica de negocio (`app/routers/`). Los dos routers del sistema implementan las reglas de acceso. El router de autenticación valida credenciales, verifica el estado de la cuenta y comprueba que el certificado digital no haya expirado antes de emitir el JWT. El router de identidades gestiona las operaciones del ciclo de vida, aplicando validaciones de jerarquía: ningún usuario puede ejecutar acciones sobre otro de igual o mayor rango. Solo los roles Admin y Coordinator reciben certificado X.509; los roles Operative y External operan únicamente con contraseña.

Interfaz de usuario (`app/frontend.html`). Se implementó un dashboard web integrado al propio servidor como una aplicación de página única (SPA) en HTML5 y JavaScript puro. La interfaz consume directamente los endpoints de la API y permite realizar todas las operaciones del sistema sin herramientas externas.

Conexión de los componentes

Los módulos se integran a través del servidor FastAPI, que actúa como punto de entrada único. Al iniciar, `main.py` crea las tablas necesarias, aplica migraciones y registra los dos routers bajo el prefijo `/api/v1`. Cada petición que llega al sistema pasa por el siguiente flujo:

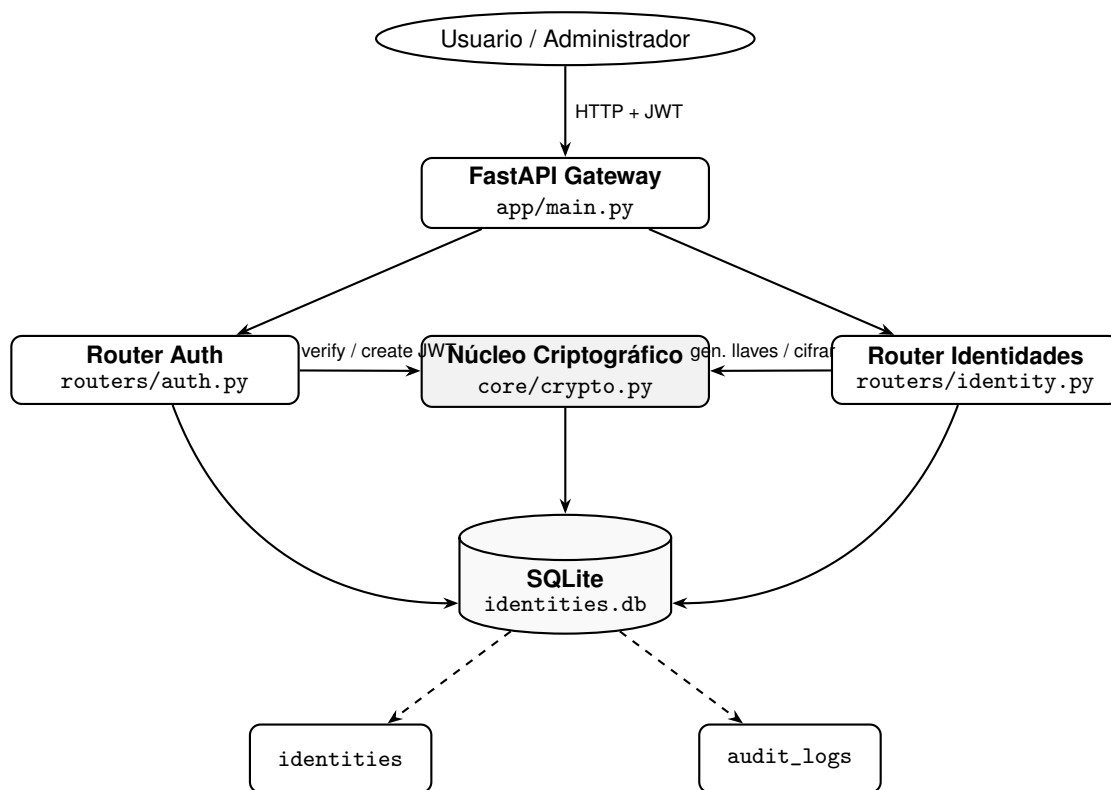


Figura 1: Arquitectura general del sistema de gestión de identidades.

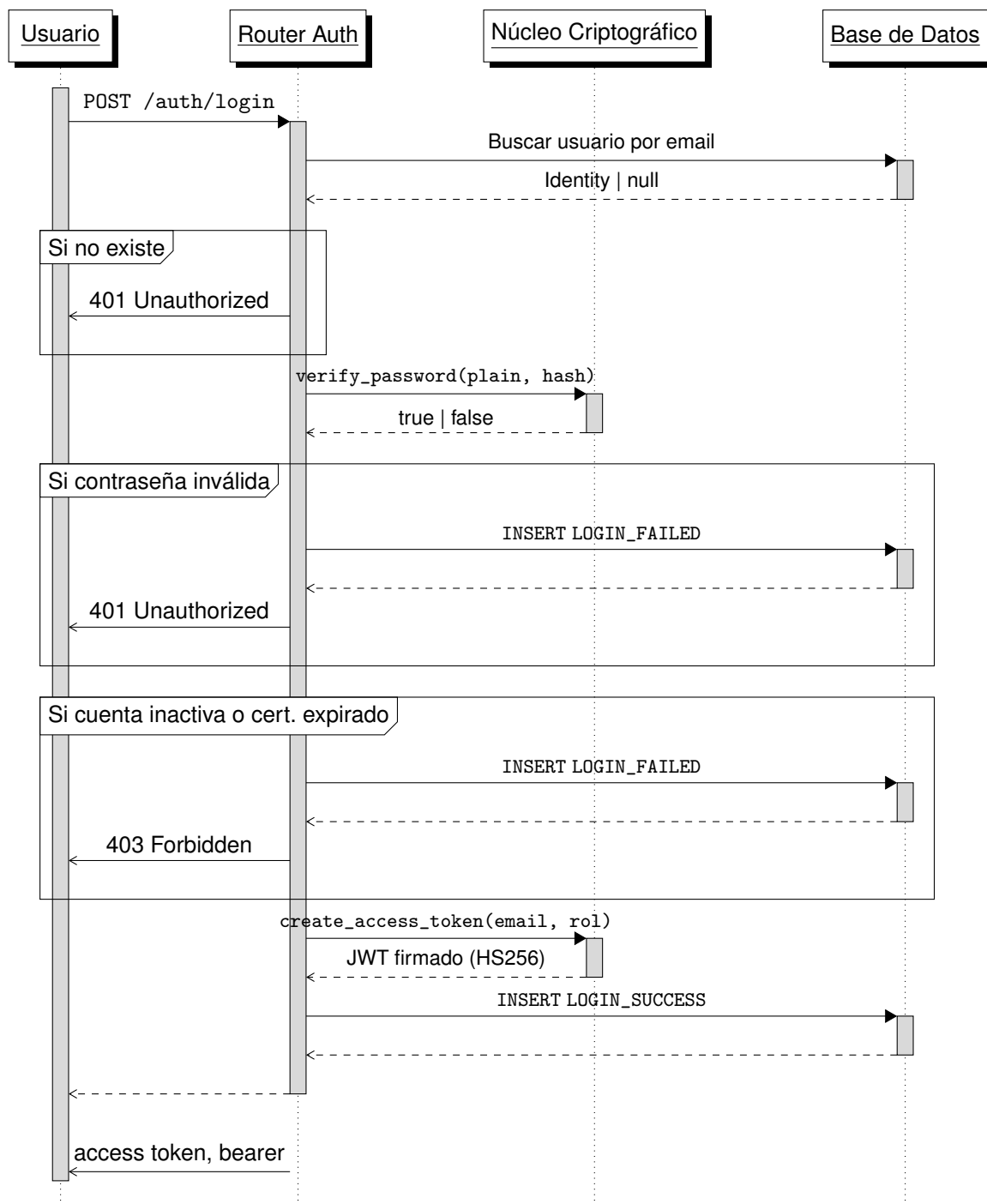


Figura 2: Diagrama de secuencia: proceso de autenticación y emisión de token JWT.

La Figura 2 describe el proceso de autenticación del sistema, el cual aplica una validación en tres capas sucesivas antes de emitir un token de acceso. En primer lugar, se verifica que el correo electrónico proporcionado corresponda a un usuario registrado; si no existe, se devuelve un error genérico 401 Unauthorized sin revelar si el correo está o no registrado, evitando así ataques de enumeración de usuarios.

En caso de que el usuario exista, se verifica la contraseña comparándola contra el hash bcrypt almacenado. Un fallo en esta etapa genera un evento LOGIN_FAILED en la tabla de auditoría antes de rechazar la petición, dejando trazabilidad de los intentos fallidos. Posteriormente, el sistema comprueba que la cuenta tenga estado ACTIVO y que el certificado digital asociado no haya expirado; ambas condiciones son independientes de la contraseña y se validan por separado.

Si las tres capas de validación son superadas, el núcleo criptográfico genera un token JWT firmado con el algoritmo HS256, que incorpora el correo electrónico y el rol del usuario como datos de sesión. El token tiene una vigencia de ocho horas y se registra el inicio de sesión exitoso en el log de auditoría.

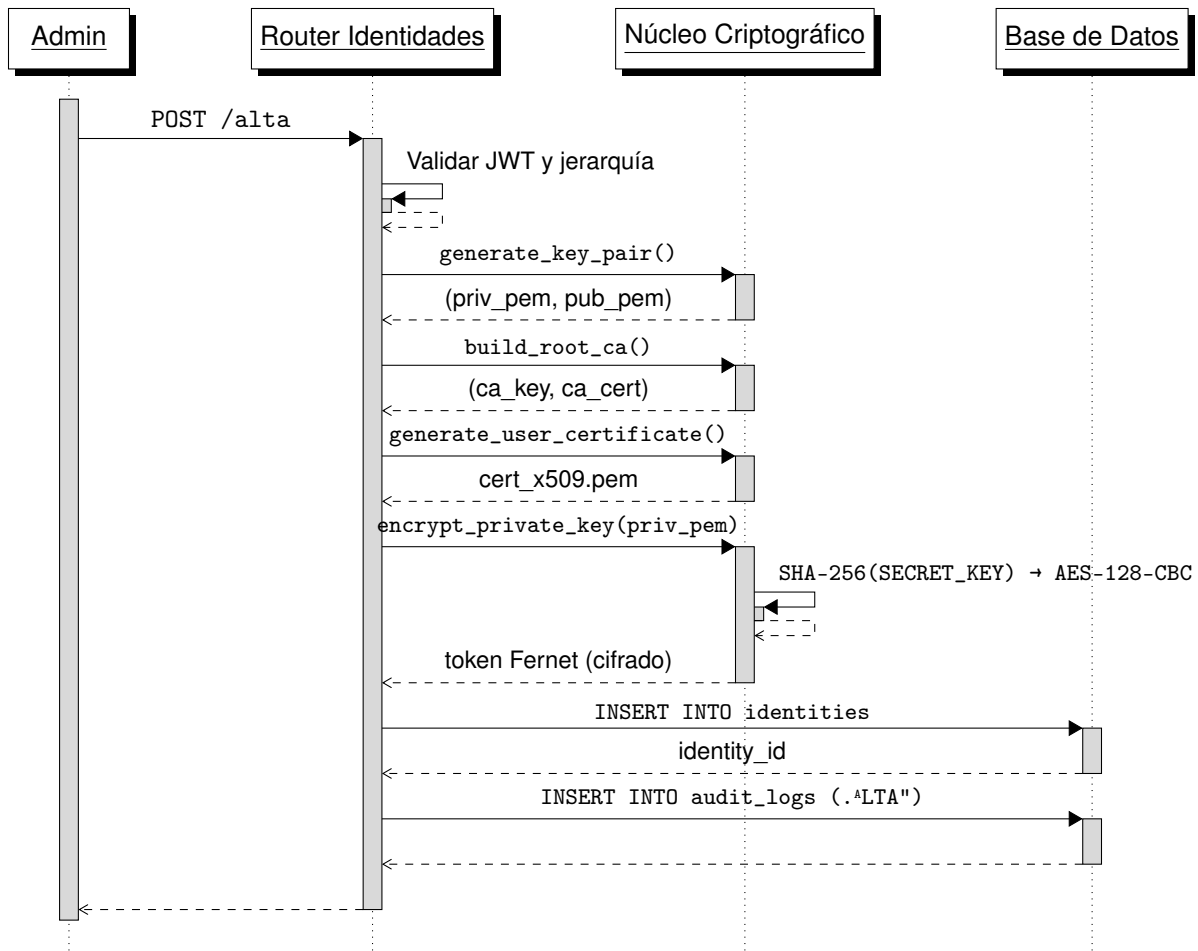


Figura 3: Diagrama de secuencia: proceso de Alta de una identidad digital.

El diagrama de la Figura 3 ilustra la secuencia de operaciones que se ejecutan cuando un administrador registra un nuevo colaborador en el sistema. El proceso inicia con una petición HTTP POST al endpoint `/api/v1/identities/alta`, acompañada de un token JWT válido en el encabezado de autorización. El router verifica primero la jerarquía de roles, asegurando que el actor tenga mayor nivel jerárquico que el rol que intenta asignar.

Una vez validado el acceso, se invoca al núcleo criptográfico en tres pasos sucesivos: se genera un par de llaves RSA de 2048 bits, se construye una Autoridad Certificadora raíz temporal y se emite un certificado X.509 firmado a nombre del nuevo colaborador. Antes de persistir el material en la base de datos, la llave privada es cifrada mediante el esquema Fernet, que aplica AES-128-CBC derivando la clave de cifrado a partir de la `SECRET_KEY` del sistema mediante una función hash SHA-256.

Finalmente, se almacena la identidad con su certificado y llave privada cifrada,

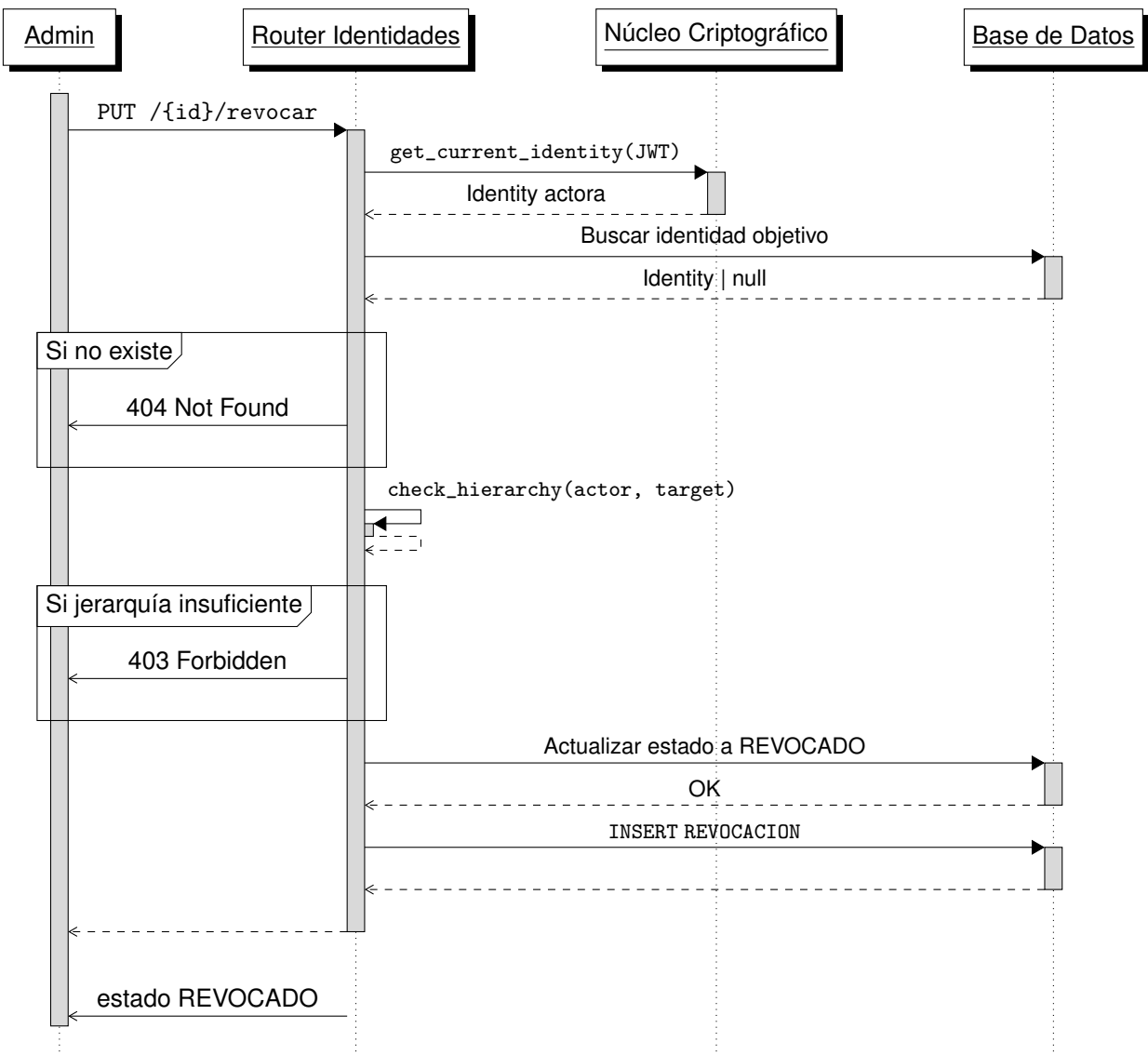


Figura 4: Diagrama de secuencia: proceso de revocación de un certificado digital.

El diagrama de la Figura 4 describe el proceso mediante el cual un administrador invalida el certificado digital de un colaborador sin eliminar su registro del sistema. La revocación es una operación de estado: el colaborador permanece en la base de datos, pero su campo `estado` cambia a `REVOCADO`, lo que impide que pueda iniciar sesión hasta que el certificado sea revalidado o renovado.

El router valida en primer lugar la sesión del actor mediante el token JWT y luego recupera la identidad objetivo. Antes de aplicar cualquier cambio, se ejecuta la verificación de jerarquía, que garantiza que ningún usuario pueda revocar el certificado de alguien de igual o mayor rango organizacional. Si la validación falla, la operación se cancela con un error `403 Forbidden`.

Una vez confirmado el acceso, el sistema actualiza el estado de la identidad directamente en la base de datos y registra el evento `REVOCACION` en la tabla de auditoría, incluyendo el identificador del actor que ejecutó la acción. Esta trazabilidad permite reconstruir el historial completo de cambios de estado de cualquier certificado en el sistema.

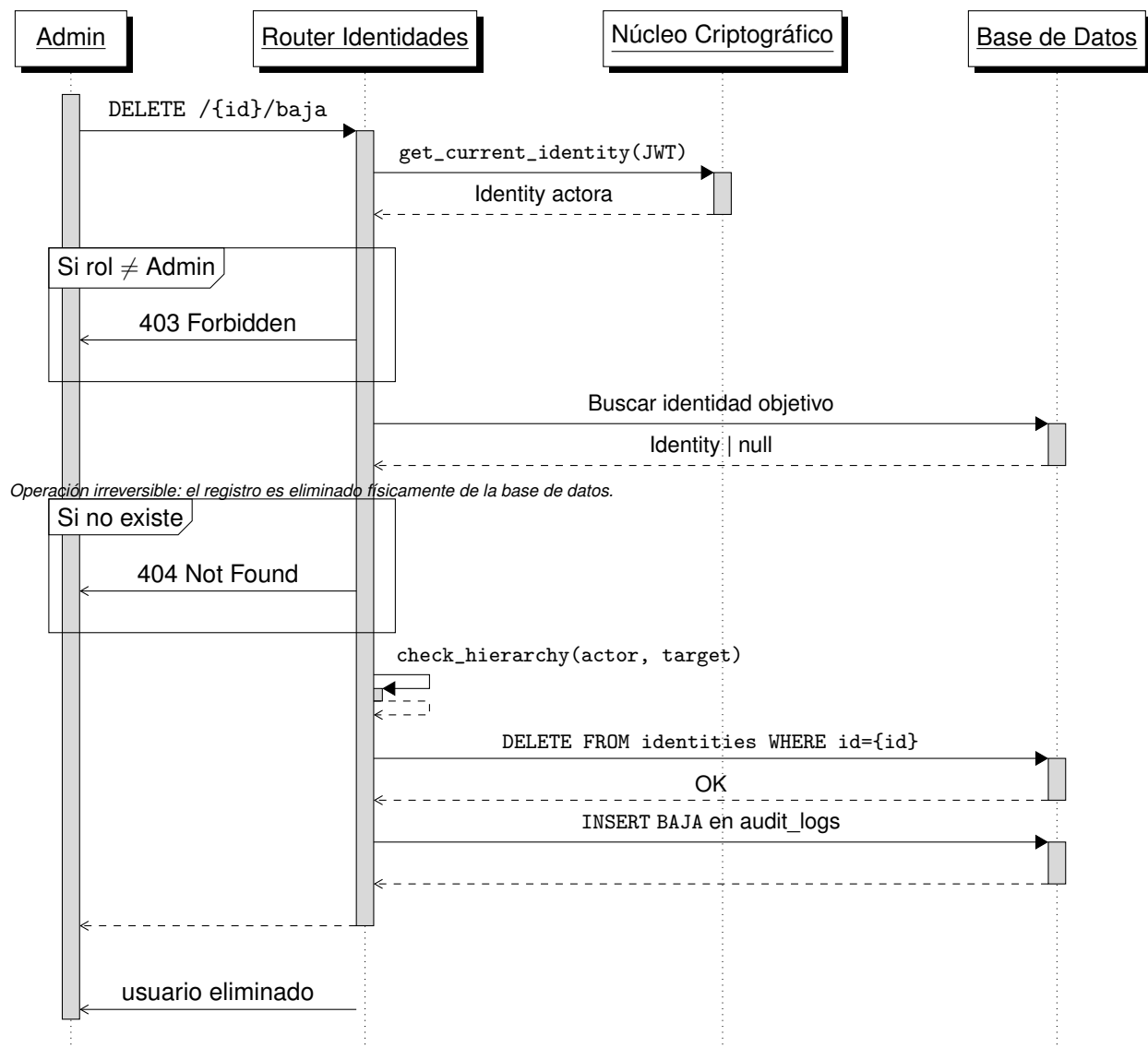


Figura 5: Diagrama de secuencia: proceso de baja definitiva (eliminación física) de una identidad.

La Figura 5 representa el flujo de la operación de baja, que constituye la eliminación física e irreversible de una identidad del sistema. A diferencia de la revocación, esta operación destruye permanentemente el registro del colaborador y todo su material criptográfico asociado en la base de datos.

Por la naturaleza crítica de la operación, el sistema aplica dos controles de acceso consecutivos. El primero restringe la ejecución exclusivamente al rol Admin, rechazando cualquier otro perfil con un error 403 Forbidden sin consultar la base de datos. El segundo control valida la jerarquía, impidiendo que un administrador pueda eliminar a otro administrador o a usuarios de nivel superior al propio.

Superados ambos controles, la eliminación se realiza mediante un *hard delete* directamente sobre la tabla *identities*. El evento BAJA se registra en la tabla de auditoría preservando el identificador de la identidad eliminada, de modo que el historial de acciones permanezca consultable aunque el registro del colaborador ya no exista en el sistema.

Resultados

Lo que se obtiene para BackEnd

El desarrollo del backend produjo una API REST completamente funcional construida con FastAPI, que expone endpoints organizados bajo los prefijos `/api/v1/auth` y `/api/v1/identities`. El resultado más relevante en esta capa es la implementación del ciclo de vida completo de una identidad digital: alta con generación automática de material criptográfico, revocación y revalidación de certificados, baja definitiva con eliminación física del registro, y descarga autenticada de llaves y certificados.

Desde el punto de vista de la seguridad, se obtuvo un esquema de protección en reposo en el que ninguna llave privada RSA se almacena en texto plano. Toda llave privada es cifrada mediante el esquema Fernet (AES-128-CBC con HMAC-SHA256) antes de ser persistida en la base de datos, y se descifra exclusivamente en memoria durante la atención de una petición autorizada. Las contraseñas de los usuarios siguen el mismo principio, almacenándose únicamente como hashes bcrypt.

La autenticación se resolvió mediante tokens JWT firmados con HS256 y vigencia de ocho horas, validados en cada petición a través de una dependencia inyectada de FastAPI. El sistema de autorización implementa una jerarquía de cuatro roles —Admin, Coordinator, Operative y External— que restringe las operaciones de forma transitiva: ningún usuario puede ejecutar acciones sobre otro de igual o mayor rango. Adicionalmente, el acceso al sistema se bloquea automáticamente si el certificado X.509 del usuario ha expirado, independientemente de que la contraseña sea correcta.

Como resultado complementario, el sistema genera un log de auditoría inmutable para cada operación relevante, registrando el actor, la acción ejecutada, la identidad afectada y la marca de tiempo. Esto proporciona trazabilidad completa sobre el ciclo de vida de cada certificado en el sistema.

Lo que se obtiene para FrontEnd

El desarrollo del frontend produjo un dashboard web integrado directamente al servidor como una aplicación de página única (SPA), accesible desde la ruta raíz del servicio sin necesidad de herramientas externas ni servidores adicionales. La interfaz consume la API REST de forma asíncrona mediante `fetch`, gestionando el token JWT en el cliente y adjuntándolo automáticamente en el encabezado de cada petición.

El resultado funcional más relevante es que el administrador puede ejecutar desde el navegador todas las operaciones del ciclo de vida: registrar nuevos colaboradores con selección de rol y vigencia del certificado, revocar y revalidar certificados, dar de baja usuarios, generar certificados efímeros con duración parametrizable y descargar el certificado, la llave pública y la llave privada de cualquier identidad autorizada, todo sin salir de la interfaz.

Desde la perspectiva de la experiencia de usuario, la interfaz presenta en tiempo real el estado de cada identidad —ACTIVO, REVOCADO o BAJA— y la fecha de vencimiento de cada certificado, facilitando la detección oportuna de certificados próximos a expirar. El log de auditoría es igualmente consultable desde el dashboard, mostrando el historial cronológico de acciones por identidad o de forma global para el administrador.

Lo que se obtiene en la solución completa

La integración del backend y el frontend produjo un sistema operativo de gestión de identidades digitales que cubre de extremo a extremo el estándar PKI aplicado a un entorno organizacional. La solución completa puede iniciarse con dos comandos —`python seed.py` y `uvicorn app.main:app`— y queda inmediatamente funcional con un administrador maestro preconfigurado.

El resultado más significativo de la solución en conjunto es que resuelve el problema de la confianza en las identidades digitales sin depender de servicios externos: la Autoridad Certificadora, la emisión de certificados, el cifrado del material sensible y la gestión de sesiones son todos procesos que ocurren dentro del mismo sistema. Esto lo hace autosuficiente y adaptable a entornos sin conectividad a proveedores de identidad externos.

En términos de seguridad global, la solución garantiza tres propiedades fundamentales: confidencialidad, ya que las llaves privadas y contraseñas nunca existen en texto plano en los medios de almacenamiento; integridad, dado que los certificados X.509 son firmados digitalmente por la CA interna y su autenticidad

puede verificarse criptográficamente; y no repudio, puesto que cada acción del sistema queda registrada en un log de auditoría con el identificador del actor responsable y una marca de tiempo generada por el servidor.

Casos de uso y tabla de validaciones

1. Pruebas - colaboradores nivel 1

1. Prueba - log in

Los colaboradores nivel 1 deben ser capaces de hacer login, lo cual se prueba exitosamente.

2. Prueba - alta nivel 1

Los colaboradores nivel 1 no deben ser capaces de dar de alta a un colaborador nivel 1, lo cual se prueba exitosamente.

3. Prueba - alta nivel 2

Los colaboradores nivel 1 deben ser capaces de dar de alta a un colaborador nivel 2, lo cual se prueba exitosamente.

4. Prueba - alta nivel 3

Los colaboradores nivel 1 deben ser capaces de dar de alta a un colaborador nivel 3, lo cual se prueba exitosamente.

5. Prueba - alta nivel 4

Los colaboradores nivel 1 deben ser capaces de dar de alta a un colaborador nivel 4, lo cual se prueba exitosamente.

6. Prueba - revocación certificados nivel 1

Los colaboradores nivel 1 no deben ser capaces de revocar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

7. Prueba - revocación certificados nivel 2

Los colaboradores nivel 1 deben ser capaces de revocar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

8. Prueba - revocación certificados nivel 3

Los colaboradores nivel 1 no deben ser capaces de revocar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

9. Prueba - revocación certificados nivel 4

Los colaboradores nivel 1 no deben ser capaces de revocar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

10. Prueba - revalidación certificados revocados nivel 1

Los colaboradores nivel 1 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 1, lo cual se prueba exitosamente.

11. Prueba - revalidación certificados revocados nivel 2

Los colaboradores nivel 1 deben ser capaces de revalidar el certificado revocado de un colaborador nivel 2, lo cual se prueba exitosamente.

12. Prueba - revalidación certificados revocados nivel 3

Los colaboradores nivel 1 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 3, lo cual se prueba exitosamente.

13. Prueba - revalidación certificados revocados nivel 4

Los colaboradores nivel 1 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 4, lo cual se prueba exitosamente.

14. Prueba - extensión certificados nivel 1

Los colaboradores nivel 1 no deben ser capaces de extender el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

15. Prueba - extensión certificados nivel 2

Los colaboradores nivel 1 deben ser capaces de extender el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

16. Prueba - extensión certificados nivel 3

Los colaboradores nivel 1 no deben ser capaces de extender el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

17. Prueba - extensión certificados nivel 4

Los colaboradores nivel 1 no deben ser capaces de extender el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

18. Prueba - baja nivel 1

Los colaboradores nivel 1 no deben ser capaces de dar de baja a un colaborador nivel 1, lo cual se prueba exitosamente.

19. Prueba - baja nivel 2

Los colaboradores nivel 1 deben ser capaces de dar de baja a un colaborador nivel 2, lo cual se prueba exitosamente.

20. Prueba - baja nivel 3

Los colaboradores nivel 1 deben ser capaces de dar de baja a un colaborador nivel 3, lo cual se prueba exitosamente.

21. Prueba - baja nivel 4

Los colaboradores nivel 1 deben ser capaces de dar de baja a un colaborador nivel 4, lo cual se prueba exitosamente.

22. Prueba - visualización certificados

Los colaboradores nivel 1 deben ser capaces de visualizar los certificados, lo cual se prueba exitosamente.

23. Prueba - descarga certificados nivel 1

Los colaboradores nivel 1 deben ser capaces de descargar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

24. Prueba - descarga certificados nivel 2

Los colaboradores nivel 1 deben ser capaces de descargar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

25. Prueba - descarga certificados nivel 3

Los colaboradores nivel 1 no deben ser capaces de descargar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

26. Prueba - descarga certificados nivel 4

Los colaboradores nivel 1 no deben ser capaces de descargar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

27. Prueba - visualización auditoría

Los colaboradores nivel 1 deben ser capaces de visualizar la auditoría, lo cual se prueba exitosamente.

2. Pruebas - colaboradores nivel 2

1. Prueba - log in

Los colaboradores nivel 2 deben ser capaces de hacer login, lo cual se prueba exitosamente.

2. Prueba - log in con certificado revocado
Los colaboradores nivel 2 con certificado revocado no deben ser capaces de hacer login, lo cual se prueba exitosamente.
3. Prueba - log in con baja
Los colaboradores nivel 2 con baja no deben ser capaces de hacer login, lo cual se prueba exitosamente.
4. Prueba - alta nivel 1
Los colaboradores nivel 2 no deben ser capaces de dar de alta a un colaborador nivel 1, lo cual se prueba exitosamente.
5. Prueba - alta nivel 2
Los colaboradores nivel 2 no deben ser capaces de dar de alta a un colaborador nivel 2, lo cual se prueba exitosamente.
6. Prueba - alta nivel 3
Los colaboradores nivel 2 no deben ser capaces de dar de alta a un colaborador nivel 3, lo cual se prueba exitosamente.
7. Prueba - alta nivel 4
Los colaboradores nivel 2 no deben ser capaces de dar de alta a un colaborador nivel 4, lo cual se prueba exitosamente.
8. Prueba - revocación certificados nivel 1
Los colaboradores nivel 2 no deben ser capaces de revocar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.
9. Prueba - revocación certificados nivel 2
Los colaboradores nivel 2 no deben ser capaces de revocar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.
10. Prueba - revocación certificados nivel 3
Los colaboradores nivel 2 no deben ser capaces de revocar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.
11. Prueba - revocación certificados nivel 4
Los colaboradores nivel 2 no deben ser capaces de revocar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.
12. Prueba - revalidación certificados revocados nivel 1
Los colaboradores nivel 2 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 1, lo cual se prueba exitosamente.
13. Prueba - revalidación certificados revocados nivel 2
Los colaboradores nivel 2 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 2, lo cual se prueba exitosamente.
14. Prueba - revalidación certificados revocados nivel 3
Los colaboradores nivel 2 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 3, lo cual se prueba exitosamente.
15. Prueba - revalidación certificados revocados nivel 4
Los colaboradores nivel 2 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 4, lo cual se prueba exitosamente.
16. Prueba - extensión certificados nivel 1
Los colaboradores nivel 2 no deben ser capaces de extender el certificado de un colaborador

nivel 1, lo cual se prueba exitosamente.

17. Prueba - extensión certificados nivel 2

Los colaboradores nivel 2 no deben ser capaces de extender el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

18. Prueba - extensión certificados nivel 3

Los colaboradores nivel 2 no deben ser capaces de extender el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

19. Prueba - extensión certificados nivel 4

Los colaboradores nivel 2 no deben ser capaces de extender el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

20. Prueba - baja nivel 1

Los colaboradores nivel 2 no deben ser capaces de dar de baja a un colaborador nivel 1, lo cual se prueba exitosamente.

21. Prueba - baja nivel 2

Los colaboradores nivel 2 no deben ser capaces de dar de baja a un colaborador nivel 2, lo cual se prueba exitosamente.

22. Prueba - baja nivel 3

Los colaboradores nivel 2 no deben ser capaces de dar de baja a un colaborador nivel 3, lo cual se prueba exitosamente.

23. Prueba - baja nivel 4

Los colaboradores nivel 2 no deben ser capaces de dar de baja a un colaborador nivel 4, lo cual se prueba exitosamente.

24. Prueba - visualización certificados

Los colaboradores nivel 2 no deben ser capaces de visualizar los certificados, lo cual se prueba exitosamente.

25. Prueba - descarga certificados nivel 1

Los colaboradores nivel 2 no deben ser capaces de descargar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

26. Prueba - descarga certificados nivel 2

Los colaboradores nivel 2 no deben ser capaces de descargar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

27. Prueba - descarga certificados nivel 3

Los colaboradores nivel 2 no deben ser capaces de descargar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

28. Prueba - descarga certificados nivel 4

Los colaboradores nivel 2 no deben ser capaces de descargar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

29. Prueba - visualización auditoría

Los colaboradores nivel 2 no deben ser capaces de visualizar la auditoría, lo cual se prueba exitosamente.

3. Pruebas - colaboradores nivel 3

1. Prueba - log in

Los colaboradores nivel 3 deben ser capaces de hacer login, lo cual se prueba exitosamente.

2. Prueba - log in con baja

Los colaboradores nivel 3 con baja no deben ser capaces de hacer login, lo cual se prueba exitosamente.

3. Prueba - alta nivel 1

Los colaboradores nivel 3 no deben ser capaces de dar de alta a un colaborador nivel 1, lo cual se prueba exitosamente.

4. Prueba - alta nivel 2

Los colaboradores nivel 3 no deben ser capaces de dar de alta a un colaborador nivel 2, lo cual se prueba exitosamente.

5. Prueba - alta nivel 3

Los colaboradores nivel 3 no deben ser capaces de dar de alta a un colaborador nivel 3, lo cual se prueba exitosamente.

6. Prueba - alta nivel 4

Los colaboradores nivel 3 no deben ser capaces de dar de alta a un colaborador nivel 4, lo cual se prueba exitosamente.

7. Prueba - revocación certificados nivel 1

Los colaboradores nivel 3 no deben ser capaces de revocar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

8. Prueba - revocación certificados nivel 2

Los colaboradores nivel 3 no deben ser capaces de revocar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

9. Prueba - revocación certificados nivel 3

Los colaboradores nivel 3 no deben ser capaces de revocar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

10. Prueba - revocación certificados nivel 4

Los colaboradores nivel 3 no deben ser capaces de revocar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

11. Prueba - revalidación certificados revocados nivel 1

Los colaboradores nivel 3 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 1, lo cual se prueba exitosamente.

12. Prueba - revalidación certificados revocados nivel 2

Los colaboradores nivel 3 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 2, lo cual se prueba exitosamente.

13. Prueba - revalidación certificados revocados nivel 3

Los colaboradores nivel 3 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 3, lo cual se prueba exitosamente.

14. Prueba - revalidación certificados revocados nivel 4

Los colaboradores nivel 3 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 4, lo cual se prueba exitosamente.

15. Prueba - extensión certificados nivel 1

Los colaboradores nivel 3 no deben ser capaces de extender el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

16. Prueba - extensión certificados nivel 2

Los colaboradores nivel 3 no deben ser capaces de extender el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

17. Prueba - extensión certificados nivel 3
Los colaboradores nivel 3 no deben ser capaces de extender el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.
 18. Prueba - extensión certificados nivel 4
Los colaboradores nivel 3 no deben ser capaces de extender el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.
 19. Prueba - baja nivel 1
Los colaboradores nivel 3 no deben ser capaces de dar de baja a un colaborador nivel 1, lo cual se prueba exitosamente.
 20. Prueba - baja nivel 2
Los colaboradores nivel 3 no deben ser capaces de dar de baja a un colaborador nivel 2, lo cual se prueba exitosamente.
 21. Prueba - baja nivel 3
Los colaboradores nivel 3 no deben ser capaces de dar de baja a un colaborador nivel 3, lo cual se prueba exitosamente.
 22. Prueba - baja nivel 4
Los colaboradores nivel 3 no deben ser capaces de dar de baja a un colaborador nivel 4, lo cual se prueba exitosamente.
 23. Prueba - visualización certificados
Los colaboradores nivel 3 no deben ser capaces de visualizar los certificados, lo cual se prueba exitosamente.
 24. Prueba - descarga certificados nivel 1
Los colaboradores nivel 3 no deben ser capaces de descargar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.
 25. Prueba - descarga certificados nivel 2
Los colaboradores nivel 3 no deben ser capaces de descargar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.
 26. Prueba - descarga certificados nivel 3
Los colaboradores nivel 3 no deben ser capaces de descargar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.
 27. Prueba - descarga certificados nivel 4
Los colaboradores nivel 3 no deben ser capaces de descargar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.
 28. Prueba - visualización auditoría
Los colaboradores nivel 3 no deben ser capaces de visualizar la auditoría, lo cual se prueba exitosamente.
4. Pruebas - colaboradores nivel 4
 1. Prueba - log in
Los colaboradores nivel 4 deben ser capaces de hacer login, lo cual se prueba exitosamente.
 2. Prueba - log in con baja
Los colaboradores nivel 4 con baja no deben ser capaces de hacer login, lo cual se prueba exitosamente.
 3. Prueba - alta nivel 1
Los colaboradores nivel 4 no deben ser capaces de dar de alta a un colaborador nivel 1, lo cual

se prueba exitosamente.

4. Prueba - alta nivel 2

Los colaboradores nivel 4 no deben ser capaces de dar de alta a un colaborador nivel 2, lo cual se prueba exitosamente.

5. Prueba - alta nivel 3

Los colaboradores nivel 4 no deben ser capaces de dar de alta a un colaborador nivel 3, lo cual se prueba exitosamente.

6. Prueba - alta nivel 4

Los colaboradores nivel 4 no deben ser capaces de dar de alta a un colaborador nivel 4, lo cual se prueba exitosamente.

7. Prueba - revocación certificados nivel 1

Los colaboradores nivel 4 no deben ser capaces de revocar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

8. Prueba - revocación certificados nivel 2

Los colaboradores nivel 4 no deben ser capaces de revocar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

9. Prueba - revocación certificados nivel 3

Los colaboradores nivel 4 no deben ser capaces de revocar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

10. Prueba - revocación certificados nivel 4

Los colaboradores nivel 4 no deben ser capaces de revocar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

11. Prueba - revalidación certificados revocados nivel 1

Los colaboradores nivel 4 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 1, lo cual se prueba exitosamente.

12. Prueba - revalidación certificados revocados nivel 2

Los colaboradores nivel 4 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 2, lo cual se prueba exitosamente.

13. Prueba - revalidación certificados revocados nivel 3

Los colaboradores nivel 4 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 3, lo cual se prueba exitosamente.

14. Prueba - revalidación certificados revocados nivel 4

Los colaboradores nivel 4 no deben ser capaces de revalidar el certificado revocado de un colaborador nivel 4, lo cual se prueba exitosamente.

15. Prueba - extensión certificados nivel 1

Los colaboradores nivel 4 no deben ser capaces de extender el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

16. Prueba - extensión certificados nivel 2

Los colaboradores nivel 4 no deben ser capaces de extender el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

17. Prueba - extensión certificados nivel 3

Los colaboradores nivel 4 no deben ser capaces de extender el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

18. Prueba - extensión certificados nivel 4

Los colaboradores nivel 4 no deben ser capaces de extender el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

19. Prueba - baja nivel 1

Los colaboradores nivel 4 no deben ser capaces de dar de baja a un colaborador nivel 1, lo cual se prueba exitosamente.

20. Prueba - baja nivel 2

Los colaboradores nivel 4 no deben ser capaces de dar de baja a un colaborador nivel 2, lo cual se prueba exitosamente.

21. Prueba - baja nivel 3

Los colaboradores nivel 4 no deben ser capaces de dar de baja a un colaborador nivel 3, lo cual se prueba exitosamente.

22. Prueba - baja nivel 4

Los colaboradores nivel 4 no deben ser capaces de dar de baja a un colaborador nivel 4, lo cual se prueba exitosamente.

23. Prueba - visualización certificados

Los colaboradores nivel 4 no deben ser capaces de visualizar los certificados, lo cual se prueba exitosamente.

24. Prueba - descarga certificados nivel 1

Los colaboradores nivel 4 no deben ser capaces de descargar el certificado de un colaborador nivel 1, lo cual se prueba exitosamente.

25. Prueba - descarga certificados nivel 2

Los colaboradores nivel 4 no deben ser capaces de descargar el certificado de un colaborador nivel 2, lo cual se prueba exitosamente.

26. Prueba - descarga certificados nivel 3

Los colaboradores nivel 4 no deben ser capaces de descargar el certificado de un colaborador nivel 3, lo cual se prueba exitosamente.

27. Prueba - descarga certificados nivel 4

Los colaboradores nivel 4 no deben ser capaces de descargar el certificado de un colaborador nivel 4, lo cual se prueba exitosamente.

28. Prueba - visualización auditoría

Los colaboradores nivel 4 no deben ser capaces de visualizar la auditoría, lo cual se prueba exitosamente.

En la Figura se muestra la tabla de pruebas que resume las pruebas descritas.

	login	login con certificado revocado	 login con baja	alta				revocar certificado				revalidar certificado				extender certificado				baja				certificados	descargar certificados				auditoria
				nivel 1	nivel 2	nivel 3	nivel 4	nivel 1	nivel 2	nivel 3	nivel 4	nivel 1	nivel 2	nivel 3	nivel 4	nivel 1	nivel 2	nivel 3	nivel 4	nivel 1	nivel 2	nivel 3	nivel 4		nivel 1	nivel 2	nivel 3	nivel 4	
nivel 1	✓	NA	NA	✗	✓	✓	✓	✗	✓	✗	✗	✗	✓	✗	✗	✗	✓	✗	✗	✗	✓	✓	✓	✓	✓	✓	✗	✗	✓
nivel 2	✓	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗
nivel 3	✓	NA	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗
nivel 4	✓	NA	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗	✗

Figura 6: tabla de pruebas

Evidencias: <https://drive.google.com/drive/folders/1Zd0faSLR4aivzJd89kkL7n2dQbMzUYz9?usp=sharing>

Conclusiones y trabajo futuro

Lo que se construyó en este proyecto es más que una API con operaciones CRUD. Es una infraestructura de confianza digital pensada específicamente para el contexto y las limitaciones reales de una organización sin fines de lucro. Cada decisión técnica, desde el uso de RSA de 2048 bits hasta el cifrado de las claves privadas con Fernet antes de almacenarlas en la base de datos, tuvo una razón concreta detrás: garantizar que el sistema sea seguro no solo cuando todo funciona bien, sino también cuando algo sale mal.

La jerarquía de roles no es decorativa. Refleja la estructura real de Casa Monarca y asegura que nadie pueda operar sobre alguien de igual o mayor nivel jerárquico que el propio. El registro de auditoría no es opcional. Es la columna vertebral del cumplimiento legal, la herramienta que convierte una buena intención en algo demostrable ante una autoridad. Y el dashboard embebido no es un extra cosmético. Es el puente entre la tecnología y las personas que realmente van a usar el sistema, que no son desarrolladores.

El proyecto demuestra que es posible implementar criptografía de llave pública de forma correcta, dentro de un presupuesto de cero pesos en licencias, con tecnologías abiertas y bien documentadas, y producir algo que una organización real pueda adoptar y mantener.

El camino que queda por recorrer es claro. En el corto plazo, el sistema necesita pruebas automatizadas, una CA raíz persistente y el cambio obligatorio de la clave secreta predeterminada antes de cualquier despliegue en producción. Sin esos tres elementos, el sistema es funcional, pero frágil.

En el mediano plazo, migrar a PostgreSQL y agregar autenticación multifactor son los dos avances más importantes, tanto en robustez técnica como en seguridad operativa. Ambos están diseñados para integrarse en la arquitectura existente sin romper nada de lo que ya funciona.

En el largo plazo, este módulo está concebido como el primero de varios. El gestor de documentos, la firma de correos, la verificación externa y los demás sistemas del reto adquieren pleno sentido cuando se apoyan sobre una capa de identidades confiable. Lo que se construyó aquí es exactamente esa capa: la base sobre la que todo lo demás puede crecer con solidez, orden y la misma lógica de seguridad que Casa Monarca necesita para cumplir su misión con tranquilidad.

Referencias

CASA MONARCA. (s.f.) INICIO. CASA MONARCA. <https://casamonarca.org.mx/>

Inteligencia artificial

Se utilizó la inteligencia artificial Chat GPT para corregir la ortografía, gramática, puntuación, coherencia, cohesión, y adecuación. Los prompts que se utilizaron y las respuestas de la inteligencia artificial Chat GPT se encuentran en el siguiente enlace:

<https://chatgpt.com/share/6a0364c0-0944-83e8-9f9e-421de3c0ee5d>